

## packages/graph-view/vite.config.ts

Kind: added · Baseline: 8e0dc031dcfc · Target: NovaDiff · Generated: 2026-05-19T19:20:54.197Z

### Overview

A new file `packages/graph-view/vite.config.ts` (lines 1-362) defines a Vite dev server that serves NovaDiff graph data, configuration, and source-file content with strict security checks.

### Key changes

- **Imports & token** – `defineConfig`, `react`, `tailwindcss`, `path`, `fs`, `crypto` are added (R2-7).  
`ACCESS_TOKEN` is generated from `NOVADIFF_GRAPH_ACCESS_TOKEN` or a random 16-byte hex string (line 12).  
`MAX_SOURCE_FILE_BYTES` limits preview size (line 13).
- **Graph utilities** – `graphFileCandidates` (15-22), `findGraphFile` (26-27), `projectRootFromGraphFile` (30-31), `normalizeGraphPath` (34-52), and `graphFilePathSet` (55-69) locate and validate graph files.
- **Language detection** – `detectLanguage` maps file extensions to language names (72-101).
- **Response helpers** – `sendJson` and `rejectFileRequest` (104-112).
- **File-content endpoint** – `readSourceFile` (114-176) validates relative paths, checks size, rejects binaries, and returns language via `detectLanguage`.
- **Middleware** – protects `/knowledge-graph.json`, `/domain-graph.json`, `/diff-overlay.json`, `/meta.json`, `/config.json`, and `/file-content.json` with the token (250-268).  
`/file-content.json` is served by `readSourceFile` (271-273).
- **Graph file sanitization** – absolute paths in graph nodes are converted to project-relative paths before sending (312-333).
- **Server config** – binds to `127.0.0.1:5173`, opens the dashboard URL with the token (187-191), and logs the URL once on startup (238-244).
- **Build** – custom Rollup chunking for large dependencies ( `react-vendor`, `xyflow`, `elk`, `graphology`, `graph-layout`, `markdown` ) (204-226).

### Impact

- **Security** – token enforcement and path validation prevent unauthorized access and path traversal (lines 250-268, 114-176).
- **Privacy** – sanitization of absolute paths avoids leaking the developer's filesystem layout (lines 312-333).
- **Performance** – early rejection of oversized or binary files keeps the server lightweight (lines 159-165).
- **Observability** – the dashboard URL is logged once at startup (lines 238-244).

### Risks & follow-ups

- **Token mismatch** – verify that the printed token matches client requests (lines 238-244).
- **Graph file absence** – 404 is returned if `knowledge-graph.json` is missing (lines 130-133, 350-354).
- **Path sanitization edge cases** – test nodes with absolute paths outside the project to confirm they are reduced to filenames (lines 328-332).
- **Binary file detection** – confirm binary files return status 415 (lines 164-165).